Cybersecurity Preparation Notes

Deloitte Cyber Gurukul 2027 – Analyst Trainee

Complete topic guide and revision checklist

Covers cybersecurity fundamentals, computer networks, web application security, cryptography, ethical hacking tools, operating systems, DBMS, programming fundamentals, SOC operations and incident response.

Important: These notes are a preparation guide based on commonly tested cybersecurity and computer-science fundamentals. They are not an official Deloitte syllabus, confirmed question distribution, or cutoff.

1. Cybersecurity Fundamentals

Cybersecurity protects computers, networks, applications and data from unauthorized access, damage, theft and disruption.

CIA Triad

Principle	Meaning	Example
Confidentiality	Only authorized people can view information.	Encryption and access permissions.
Integrity	Information remains accurate and is not changed without authorization.	Hash checks and digital signatures.
Availability	Systems and information are accessible when needed.	Backups, redundancy and DDoS protection.

Core terms

Term	Meaning
Threat	A possible cause of harm, such as an attacker or malware.
Vulnerability	A weakness that could be exploited.
Exploit	A method or code that takes advantage of a vulnerability.
Risk	The possibility and impact of a threat exploiting a vulnerability.
Attack surface	All points where an attacker could try to enter or extract data.

Security principles

• **Least privilege:** Give users and programs only the permissions they need.

• **Defense in depth:** Use multiple layers of security rather than relying on one control.

• **Zero Trust:** Do not automatically trust a user or device; verify access continuously.

• **Need to know:** Provide access only to information required for a task.

• **Security by design:** Consider security throughout system development.

Authentication, authorization and accounting

• **Authentication:** Verifies who a user is.

• **Authorization:** Determines what an authenticated user can do.

• **Accounting/Auditing:** Records actions and access for review.

• **MFA:** Uses two or more different factor types, such as password plus authenticator app.

2. Types of Attacks and Malware

Attack / malware	Meaning / key point
Phishing	Fraudulent message designed to steal credentials or make a victim perform an unsafe action.
Spear phishing	Targeted phishing aimed at a specific person or organization.
Ransomware	Malware that encrypts or blocks access to data and demands payment.

Attack / malware	Meaning / key point
Virus	Malicious code that attaches to a file or program and typically needs execution.
Worm	Self-replicating malware that can spread across systems or networks.
Trojan	Malware disguised as legitimate software.
Spyware	Software that secretly collects information.
DoS / DDoS	Attempts to make a service unavailable; DDoS uses multiple sources.
Spoofing	Faking an identity or source, such as an IP, email or ARP identity.
Sniffing	Capturing and inspecting network traffic.
Brute force	Trying many possible passwords or credentials.
Man-in-the-middle	An attacker intercepts or potentially alters communication between parties.
Social engineering	Manipulating people into revealing information or taking unsafe actions.

Common social engineering methods

• **Baiting:** Luring a victim with something attractive, such as a supposedly free download.

• **Pretexting:** Inventing a believable scenario to obtain information.

• **Tailgating:** Following an authorized person into a restricted physical area.

• **Quid pro quo:** Offering a service or benefit in exchange for information or access.

3. Computer Networks and Network Security

OSI model – memorize the seven layers from top to bottom.

Layer	Name	Typical examples / role
7	Application	HTTP, HTTPS, DNS, SMTP; services used by applications.
6	Presentation	Data format, encoding, compression and encryption representation.
5	Session	Establishes, manages and ends communication sessions.
4	Transport	TCP, UDP; end-to-end delivery and ports.
3	Network	IP addressing and routing.
2	Data Link	Frames, MAC addresses and switching.
1	Physical	Bits, cables, radio signals and connectors.

TCP vs UDP

TCP	UDP
Connection-oriented; reliable, ordered delivery; retransmission and flow control.	Connectionless; lower overhead; no guarantee of delivery or order.
Commonly used by HTTPS, SSH, email and file transfer.	Commonly used by DNS queries, streaming, voice and online games.

TCP three-way handshake

• 1. SYN: Client requests a connection.

• 2. SYN-ACK: Server acknowledges and responds.

• 3. ACK: Client acknowledges; the connection is established.

Important ports

Port	Service	Remember
20/21	FTP	File transfer data/control (traditional FTP).
22	SSH	Secure remote login.
23	Telnet	Unencrypted remote login.
25	SMTP	Email transfer.
53	DNS	Domain name resolution.
67/68	DHCP	Automatic IP configuration (server/client).
80	HTTP	Web traffic, not encrypted by itself.
110	POP3	Email retrieval.
143	IMAP	Email access and synchronization.
443	HTTPS	HTTP protected by TLS.
3389	RDP	Remote Desktop Protocol.

Other networking concepts

• **IP address:** Logical address used to identify a device/interface on an IP network.

• **MAC address:** Link-layer hardware/interface address used on a local network.

• **IPv4:** 32-bit address; **IPv6:** 128-bit address.

• **Private IP:** Used inside private networks; generally not routed directly on the public internet.

• **DNS:** Resolves domain names to IP addresses and other DNS records.

• **DHCP:** Automatically leases IP configuration to clients.

• **ARP:** Maps an IPv4 address to a link-layer address on a local network.

• **VPN:** Creates a protected tunnel across an untrusted network.

• **NAT:** Translates IP addresses, commonly between private and public networks.

• **Firewall:** Allows or blocks traffic according to security rules.

• **Proxy:** Acts as an intermediary for client requests.

• **IDS:** Detects suspicious activity and generates alerts.

• **IPS:** Can actively block or prevent detected malicious traffic.

4. Web Application Security and OWASP

Web application vulnerabilities often arise from unsafe input handling, weak access control, insecure configuration or poor session management.

Vulnerability	Meaning	Typical defense
SQL Injection	Untrusted input changes the meaning of a database query.	Parameterized queries; least-privilege database accounts.
Cross-Site Scripting (XSS)	Attacker-controlled script executes in another user's browser.	Context-aware output encoding; safe templating; CSP as defense-in-depth.
CSRF	A browser is tricked into sending an unwanted authenticated request.	Anti-CSRF tokens; SameSite cookies; origin checks where appropriate.
Broken Access Control	A user accesses data or actions beyond their permission.	Server-side authorization checks on every request.
Clickjacking	A user is tricked into clicking an obscured or embedded interface.	CSP frame-ancestors; X-Frame-Options for legacy support.
Directory Traversal	Path manipulation reaches files outside the intended directory.	Canonicalize and validate paths; restrict file access.
Brute Force	Repeated credential guesses.	Rate limiting, MFA, monitoring and secure password storage.
Session Hijacking	An attacker obtains or abuses a valid session token.	TLS, secure cookie flags, rotation and session expiration.

OWASP Top 10 – learn the category names

• Broken Access Control

• Cryptographic Failures

• Injection

• Insecure Design

• Security Misconfiguration

• Vulnerable and Outdated Components

• Identification and Authentication Failures

• Software and Data Integrity Failures

• Security Logging and Monitoring Failures

• Server-Side Request Forgery (SSRF)

HTTP security headers and cookies

• **Content-Security-Policy (CSP):** Helps control which sources a browser may load content from.

• **Strict-Transport-Security (HSTS):** Tells browsers to use HTTPS for a specified period.

• **X-Frame-Options:** Helps restrict framing; CSP frame-ancestors is the modern flexible control.

• **HttpOnly cookie:** Prevents ordinary JavaScript access to the cookie.

• **Secure cookie:** Sends the cookie only over secure HTTPS connections.

• **SameSite cookie:** Helps control when cookies are sent with cross-site requests.

5. Cryptography

Concept	Meaning / key fact
Plaintext	Original readable data.
Ciphertext	Encrypted, unreadable representation.
Encryption	Transforms plaintext into ciphertext using an algorithm and key.
Decryption	Transforms ciphertext back into plaintext using the appropriate key.
Hashing	Produces a fixed-size digest; a secure hash is designed to be one-way.
Salt	Random value added to password input before hashing to resist precomputed attacks.
AES	Modern symmetric block cipher; same secret key is used for encryption and decryption.
DES	Older 56-bit-key block cipher; no longer considered secure.
RSA	Public-key cryptosystem used for encryption/key establishment and signatures in suitable schemes.
SHA-256	SHA-2 hash function producing a 256-bit digest.
MD5	Produces a 128-bit digest; not suitable for security-sensitive collision resistance.
Digital signature	Uses a private key to sign; public key verifies authenticity and integrity.
PKI	Framework of certificates, certificate authorities and public-key trust.
TLS	Protocol that protects data in transit and authenticates the server; HTTPS uses HTTP over TLS.

Symmetric vs asymmetric encryption

Symmetric	Asymmetric
Uses one shared secret key; efficient for bulk data.	Uses a public/private key pair; useful for key exchange and digital signatures.
Example: AES.	Example: RSA.

Avalanche effect

A small change in the input should produce a large, unpredictable change in the output bits of a cryptographic hash or cipher. For an ideal hash, changing one input bit changes about half the output bits on average.

Important distinction

Hashing is not encryption: hashing is designed to be one-way, while encryption is designed to be reversible with the correct key. Passwords should be stored with a password-hashing scheme such as Argon2, bcrypt or scrypt, not plain MD5 or SHA-256 alone.

6. Ethical Hacking, VAPT and Security Tools

Tool	Common purpose
Nmap	Network discovery, port scanning and service/version detection.
Wireshark	Captures and analyzes network packets.
Burp Suite	Intercepts and tests web application traffic.

Tool	Common purpose
OWASP ZAP	Web application security testing and proxy scanning.
Metasploit	Penetration-testing framework for validating vulnerabilities in authorized environments.
Nessus	Vulnerability scanning and assessment.
John the Ripper	Password auditing and recovery testing.
Snort	Network intrusion detection/prevention using rules.

VAPT concepts

• **Vulnerability Assessment:** Identifies and prioritizes weaknesses.

• **Penetration Testing:** Safely attempts to exploit weaknesses to demonstrate impact, within an agreed scope.

• **Black-box testing:** Tester has little or no internal knowledge.

• **White-box testing:** Tester has extensive internal knowledge.

• **Grey-box testing:** Tester has partial knowledge.

• **Passive reconnaissance:** Collects information without directly interacting with the target systems.

• **Active reconnaissance:** Interacts with target systems, such as through authorized scanning.

Always obtain explicit authorization and follow the defined scope before scanning or testing systems.

7. Operating Systems and Linux

Topic	Key points
Process	A program in execution, with its own process resources.
Thread	A unit of execution within a process; threads commonly share process memory.
Scheduling	FCFS, SJF, Priority and Round Robin are common CPU scheduling algorithms.
Deadlock	Processes wait indefinitely for resources; four classic conditions are mutual exclusion, hold and wait, no preemption and circular wait.
Paging	Memory management that divides virtual memory into fixed-size pages.
Virtual memory	Allows processes to use a virtual address space backed by RAM and storage.
User / root	Linux users have permissions; root has broad administrative privileges.

Useful Linux commands

Command	Purpose
pwd	Show current directory.
ls	List files and directories.
cd	Change directory.
mkdir	Create a directory.
cat	Display file contents.

Command	Purpose
grep	Search text using a pattern.
chmod	Change file permissions.
ps	Show process information.
top	Display running processes and resource use.
ip addr	Show network interface addresses.
ping	Test reachability using ICMP where permitted.
ss -tuln	Show listening sockets/ports.

8. DBMS and SQL

Concept	Meaning
Primary key	Uniquely identifies each row; cannot be NULL.
Foreign key	References a key in another or the same table to maintain relationships.
Candidate key	A minimal set of attributes that uniquely identifies a row.
Composite key	A key made from more than one column.
Normalization	Organizes data to reduce redundancy and update anomalies.
1NF	Each field contains an atomic value; no repeating groups.
2NF	In 1NF and no partial dependency on part of a candidate key.
3NF	In 2NF and no transitive dependency of non-key attributes on a key.
ACID	Atomicity, Consistency, Isolation and Durability.
INNER JOIN	Returns matching rows from both tables.
LEFT JOIN	Returns all left-table rows and matching right-table rows.

DELETE vs TRUNCATE vs DROP

• **DELETE:** Removes selected rows; can use a WHERE clause.

• **TRUNCATE:** Removes all rows from a table, with database-specific behavior and restrictions.

• **DROP:** Removes the table object itself, including its definition.

SQL injection prevention

Use parameterized queries/prepared statements, validate input appropriately, avoid building SQL by string concatenation, and give the application database account only the permissions it needs.

9. Programming Fundamentals and Python

Prepare language-independent programming concepts as well as Python syntax and output questions.

• **Data types:** int, float, str, bool and None.

• **Collections:** list (mutable ordered), tuple (immutable ordered), set (unique elements), dictionary (key-value mapping).

• **Control flow:** if/elif/else, for and while loops.

• **Functions:** Parameters, return values, scope and recursion.

• **OOP:** Class, object, inheritance, encapsulation, polymorphism and abstraction.

• **Exceptions:** try, except, else and finally.

• **Data structures:** Arrays/lists, stacks, queues, linked lists, trees, graphs and hash tables.

• **Complexity:** Understand O(1), O(log n), O(n), O(n log n) and $O(n^2)$.

Coding practice priorities

• Arrays: largest/second largest, two sum, rotate array, remove duplicates.

• Strings: palindrome, anagram, character frequency, first non-repeating character.

• Hashing: frequency maps, duplicate detection and pair-sum problems.

• Searching and sorting: linear search, binary search and basic sorting.

• Math: prime check, GCD, factorial and Fibonacci.

• Basic recursion and simple problem-solving.

10. SOC, SIEM and Incident Response

Term	Meaning
SOC	Security Operations Center; team/function that monitors and responds to security events.
SIEM	Collects and correlates logs/events to support detection, investigation and reporting.
Log analysis	Reviewing system, application and network records to identify unusual activity.
IOC	Indicator of Compromise, such as a malicious IP, file hash or domain.
IOA	Indicator of Attack; behavior suggesting an attack is underway.
False positive	Benign activity incorrectly flagged as suspicious.
Threat intelligence	Context about threat actors, tactics, techniques, infrastructure and indicators.

Incident response lifecycle

• 1. Preparation – policies, tools, roles and plans.

• 2. Detection and analysis – identify and validate the incident.

• 3. Containment – limit spread and impact.

• 4. Eradication – remove the cause, malware or attacker access.

• 5. Recovery – restore systems and monitor them.

• 6. Lessons learned – document findings and improve controls.

Splunk basics

Splunk is commonly used to search, analyze and visualize machine-generated data such as logs. Learn what an index, event, field, search query and alert are. A SIEM is a category of security solution; Splunk Enterprise Security is a SIEM product built on Splunk.

11. Quick Revision: Common Comparisons

Compare	Remember
IDS vs IPS	IDS detects and alerts; IPS can block/prevent.
Threat vs vulnerability	Threat can cause harm; vulnerability is a weakness.
Authentication vs authorization	Who are you? vs What are you allowed to do?
Hashing vs encryption	One-way digest vs reversible transformation with key.
HTTP vs HTTPS	HTTPS protects HTTP traffic using TLS.
TCP vs UDP	Reliable, ordered stream vs connectionless datagrams without delivery guarantees.
Virus vs worm	Virus typically attaches to a host file; worm can self-spread.
Firewall vs antivirus	Network/host traffic control vs detecting/preventing malicious software.
Vulnerability assessment vs penetration test	Find and prioritize weaknesses vs validate exploitability and impact.

12. Practice MCQs

Q1. Which part of the CIA Triad ensures data is not changed without authorization?

A. Confidentiality

B. Integrity

C. Availability

D. Authentication

Answer: B – Integrity.

Q2. Which port is commonly used by HTTPS?

A. 21

B. 22

C. 80

D. 443

Answer: D – Port 443.

Q3. Which protocol resolves domain names to IP addresses?

A. DHCP

B. DNS

C. FTP

D. SMTP

Answer: B – DNS.

Q4. Which tool is commonly used to capture and analyze packets?

A. Wireshark

B. Word

C. Excel

D. PowerPoint

Answer: A – Wireshark.

Q5. What is the main purpose of a hash function?

A. Compress a file

B. Produce a fixed-size digest

C. Decrypt data

D. Assign an IP address

Answer: B – Produce a fixed-size digest.

Q6. Which attack injects malicious SQL into an application query?

A. XSS

B. CSRF

C. SQL Injection

D. DDoS

Answer: C – SQL Injection.

Q7. What does IDS primarily do?

A. Detects suspicious activity

B. Assigns IP addresses

C. Encrypts disks

D. Hosts websites

Answer: A – Detects suspicious activity.

Q8. Which is a symmetric encryption algorithm?

A. RSA

B. AES

C. SHA-256

D. MD5

Answer: B – AES.

Q9. What is least privilege?

A. Give everyone admin rights

B. Give only required permissions

C. Disable all accounts

D. Share passwords

Answer: B – Give only required permissions.

Q10. What does MFA require?

A. Multiple usernames

B. Two or more different authentication factor types

C. Two browsers

D. Two IP addresses

Answer: B – Two or more different factor types.

13. Final Preparation Checklist

- ■ Memorize OSI layers and common port numbers.
- ■ Understand TCP/UDP and the TCP three-way handshake.
- ■ Know DNS, DHCP, HTTP, HTTPS, VPN, NAT and ARP.
- ■ Revise CIA Triad, threat, vulnerability, risk and exploit.
- ■ Differentiate IDS, IPS, firewall, antivirus and SIEM.
- ■ Understand phishing, malware, spoofing, sniffing, DoS and DDoS.
- ■ Learn SQL Injection, XSS, CSRF and broken access control.
- ■ Compare AES, DES, RSA, hashing and digital signatures.
- ■ Know the purpose of Nmap, Wireshark, Burp Suite, ZAP and Metasploit.
- ■ Revise Linux commands, OS basics, DBMS, SQL and Python fundamentals.
- ■ Understand SOC, IOC, IOA, incident response and log analysis.
- ■ Practise array and string coding questions.

Suggested study order

1. Computer Networks → 2. Cybersecurity Fundamentals → 3. OWASP/Web Security → 4. Cryptography → 5. Ethical Hacking Tools → 6. OS and Linux → 7. DBMS/SQL → 8. Python → 9. SOC/SIEM and Incident Response.

Use these notes as a foundation. Confirm the actual test sections, permitted programming languages, timing and rules from the official assessment invitation.